

EXPERIMENT 18

Vulnerabilities Analysis Using CGI Scanning with Nikto

1. Aim

To perform vulnerability analysis of a web server using Nikto, focusing on CGI (Common Gateway Interface) directory scanning, detection of dangerous files, outdated software, misconfigurations, and known vulnerabilities, and to interpret the scan results for security assessment.

2. Procedure

Step 1: Start Nikto

```
kali@kali: -
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nikto -h
Option host requires an argument

Options:
-Add-header      Add HTTP headers (can be used multiple times, one per header pair)
-ask+           Whether to ask about submitting updates
                  yes   Ask about each (default)
                  no   Don't ask, don't send
                  auto  Don't ask, just send
-check6         Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
-Cgidirs+       Scan these CGI dirs: "none", "all", or values like "/cgi/" /cgi-a/"
-config+        Use this config file
-Display+       Turn on/off display outputs:
                  1   Show redirects
                  2   Show cookies received
                  3   Show all 200/OK responses
                  4   Show URLs which require authentication
                  D   Debug output
                  E   Display all HTTP errors
                  P   Print progress to STDOUT
                  S   Scrub output of IPs and hostnames
                  V   Verbose output
-dbcheck        Check database and other key files for syntax errors
-evasion+       Encoding technique:
                  1   Random URI encoding (non-UTF8)
                  2   Directory self-reference (../)
                  3   Premature URL ending
                  4   Prepend long random string
                  5   Fake parameter
                  6   TAB as request spacer
                  7   Change the case of the URL
                  8   Use Windows directory separator (\)
                  A   Use a carriage return (0x0d) as a request spacer
                  B   Use binary value 0x0b as a request spacer
-followredirects Follow 3xx redirects to new location
-Format+        Save file (-o) format:
                  csv  Comma-separated-value
                  json JSON Format
                  htm  HTML Format
                  sql  Generic SQL (see docs for schema)
                  txt  Plain text
                  xml  XML Format
                  (if not specified the format will be taken from the file extension passed to -output)
-Help           This help information
-host+         Target host/URL
-id+           Host authentication to use, format is id:pass or id:pass:realm
-ipv4          IPv4 Only
-ipv6          IPv6 Only
-key+          Client certificate key file
```

```
kali@kali: -
Session Actions Edit View Help
-ipv4 IPv4 Only
-ipv6 IPv6 Only
-key+ Client certificate key file
-list-plugins List all available plugins, perform no testing
-maxtime+ Maximum testing time per host (e.g., 1h, 60m, 3600s)
-mutate+ Guess additional file names:
1 Test all files with all root directories
2 Guess for password file names
3 Enumerate user names via Apache (/user type requests)
4 Enumerate user names via cgiwrap (/cgi-bin/cgiwrap/-user type requests)
6 Attempt to guess directory names from the supplied dictionary file

-mutate-options Provide information for mutates
-nocheck Don't check for updates on startup
-nocookies Do not use cookies from responses in requests
-nointeractive Disables interactive features
-nolookup Disables DNS lookups
-nossl Disables the use of SSL
-noslash Strip trailing slash from URL (e.g., '/admin/' to '/admin')
-no404 Disables nikto attempting to guess a 404 page
-option Over-ride an option in nikto.conf, can be issued multiple times
-output+ Write output to this file ('.' for auto-name)
-pause+ Pause between tests (seconds)
-platform+ Platform of target (nix, win, all)
-plugins+ List of plugins to run (default: ALL)
-port+ Port to use (default 80)
-RSAcert+ Client certificate file
-root+ Prepend root value to all requests, format is /directory
-save Save positive responses to this directory ('.' for auto-name)
-ssl Force ssl mode on port
-tuning+ Scan tuning:
1 Interesting File / Seen in logs
2 Misconfiguration / Default File
3 Information Disclosure
4 Injection (XSS/Script/HTML)
5 Remote File Retrieval - Inside Web Root
6 Denial of Service
7 Remote File Retrieval - Server Wide
8 Command Execution / Remote Shell
9 SQL Injection
0 File Upload
a Authentication Bypass
b Software Identification
c Remote Source Inclusion
d Webservice
e Administrative Console
x Reverse Tuning Options (i.e., include all except specified)

-timeout+ Timeout for requests (default 10 seconds)
-userdbs Load only user databases, not the standard databases
all Disable standard dbs and load only user dbs
tests Disable only db_tests and load udb_tests
-useragent Force User-Agent instead of pulling from database
```

```
kali@kali: -
Session Actions Edit View Help

- timeout+      Timeout for requests (default 10 seconds)
- Userdb+       Load only user databases, not the standard databases
                  all   Disable standard dbs and load only user dbs
                  tests Disable only db tests and load udb tests
- useragent      Force User-Agent instead of pulling from database
- url+          Target host/URL (alias of -host)
- useproxy       Use the proxy defined in nikto.conf, or argument http://server:port
- Version       Print plugin and database versions
- vhost+        Virtual host (for Host header)
- 404code        Ignore these HTTP codes as negative responses (always). Format is "302,301".
- 404string      Ignore this string in response body content as negative response (always). Can be a regular expression.
                  + requires a value

(kali@kali)-[~]
$ nikto -h http://example.com
- Nikto v2.6.0

+ Target IP:      104.20.23.154
+ Target Hostname: example.com
+ Target Port:    80
+ Platform:       Unknown
+ Start Time:     2026-08-06 23:31:20 (GMT-4)

+ Server: cloudflare
+ Multiple IPs found: 104.20.23.154, 172.66.147.243, 2606:4700:10::ac42:93f3, 2606:4700:10::6814:179a
+ ERROR: Failed to check for updates: 403
+ [999106] /: Cloudflare detected via cf-ray header. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks.
  See: https://github.com/sullo/nikto/wiki/Using-a-Proxy
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [800264] /: cloudflare - Cloudflare detected via banner. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks if not already proxying.
+ ERROR: ** Error limit (20) reached for host, giving up. Last error: error reading HTTP response. **
+ ERROR: ** Consider using mitmproxy to avoid TLS fingerprinting. **
- STATUS: Completed 478 requests (~7% complete, ~5.9 minutes left): currently in plugin 'shellshock'
- STATUS: Running average: Not enough data.
+ Scan terminated: 20 errors and 7 items reported on the remote host
+ End Time:       2026-08-06 23:31:44 (GMT-4) (24 seconds)

+ 1 host(s) tested
```

Step 2: Specify Port

nikto -h http://example.com -p 8080

Use SSL:

nikto -h https://example.com -ssl

```
kali@kali: ~  
Session Actions Edit View Help  
+ End Time: 2026-08-06 23:37:11 (GMT-4) (22 seconds)  
+ 1 host(s) tested  
  
(kali@kali)~  
$ nikto -h http://example.com -p 8080  
- Nikto v2.6.0  
  
- ERROR: The -port option cannot be used with a full URI  
  
(kali@kali)~  
$ nikto -h https://example.com -ssl  
- Nikto v2.6.0  
  
+ Target IP: 172.66.147.243  
+ Target Hostname: example.com  
+ Target Port: 443  
  
+ SSL Info: Subject: /CN=example.com  
CN: example.com  
SAN: example.com, *.example.com  
Ciphers: TLS_AES_256_GCM_SHA384  
Issuer: /C=US/O=SSL Corporation/CN=Cloudflare TLS Issuing ECC CA 3  
+ Platform: Unknown  
+ Start Time: 2026-08-06 23:39:45 (GMT-4)  
  
+ Server: cloudflare  
+ Multiple IPs found: 172.66.147.243, 104.20.23.154, 2606:4700:10::ac42:93f3, 2606:4700:10::6814:179a  
+ ERROR: Failed to check for updates: 403  
+ [999106] /: Cloudflare detected via cf-ray header. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks  
+ See: https://github.com/sullo/nikto/wiki/Using-a-Proxy  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999966] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack.  
+ See: http://breachattack.com/  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ ERROR: ** Error limit (20) reached for host, giving up. Last error: opening stream: ssl connect failed. **  
+ ERROR: ** Consider using mitmproxy to avoid TLS fingerprinting. **  
- STATUS: Completed 112 requests (~2% complete, ~20.1 minutes left): currently in plugin 'Site Files'  
- STATUS: Running average: Not enough data.  
+ Scan terminated: 20 errors and 7 items reported on the remote host  
+ End Time: 2026-08-06 23:40:04 (GMT-4) (19 seconds)
```

Step 3:

Save Scan in HTML:

nikto -h http://example.com -o scan.html -Format html

Display Version:

nikto -Version

Nikto Configuration File:

nikto -config /path/to/nikto.conf

```
kali@kali: ~  
Session Actions Edit View Help  
+ Scan terminated: 20 errors and 7 items reported on the remote host  
+ End Time: 2026-08-06 23:40:04 (GMT-4) (19 seconds)  
  
+ 1 host(s) tested  
  
(kali@kali)~  
$ nikto -h http://example.com -o scan.html -Format html  
- Nikto v2.6.0  
  
+ Target IP: 104.20.23.154  
+ Target Hostname: example.com  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-08-06 23:40:26 (GMT-4)  
  
+ Server: cloudflare  
+ Multiple IPs found: 104.20.23.154, 172.66.147.243, 2606:4700:10::6814:179a, 2606:4700:10::ac42:93f3  
+ ERROR: Failed to check for updates: 403  
+ [999106] /: Cloudflare detected via cf-ray header. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks  
+ See: https://github.com/sullo/nikto/wiki/Using-a-Proxy  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [800264] /: Cloudflare - Cloudflare detected via banner. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks if not already proxying.  
+ ERROR: ** Error limit (20) reached for host, giving up. Last error: error reading HTTP response. **  
+ ERROR: ** Consider using mitmproxy to avoid TLS fingerprinting. **  
+ STATUS: Completed 478 requests (~7% complete, ~7.1 minutes left): currently in plugin 'shellshock'  
+ STATUS: Running average: Not enough data.  
+ Scan terminated: 20 errors and 7 items reported on the remote host  
+ End Time: 2026-08-06 23:40:55 (GMT-4) (29 seconds)  
  
+ 1 host(s) tested  
  
(kali@kali)~  
$ nikto -Version  
Nikto 2.6.0 (LW 2.5)  
  
(kali@kali)~  
$ nikto -config /path/to/nikto.conf  
- Nikto v2.6.0  
  
+ ERROR: Failed to check for updates: 403
```

```
kali@kali: ~  
Session Actions Edit View Help  
- Nikto v2.6.0  
  
+ ERROR: Failed to check for updates: 403  
+ ERROR: No host (-host) specified  
  
Options:  
-Add-header Add HTTP headers (can be used multiple times, one per header pair)  
-ask Whether to ask about submitting updates  
yes Ask about each (default)  
no Don't ask, don't send  
auto Don't ask, just send  
-check6 Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)  
-Cgldirs Scan these CGI dirs: "none", "all", or values like "/cgi/" or "/cgi-bin/"  
-config Use this config file  
-Display Turn on/off display outputs:  
1 Show redirects  
2 Show cookies received  
3 Show all 200/OK responses  
4 Show URLs which require authentication  
D Debug output  
E Display all HTTP errors  
P Print progress to STDOUT  
S Scrub output of IPs and hostnames  
V Verbose output  
-dbcheck Check database and other key files for syntax errors  
-evasion Encoding technique:  
1 Random URI encoding (non-UTF8)  
2 Directory self-reference (/./)  
3 Premature URL ending  
4 Prepend long random string  
5 Fake parameter  
6 TAB as request spacer  
7 Change the case of the URL  
8 Use Windows directory separator (\)  
A Use a carriage return (0x0d) as a request spacer  
B Use binary value 0x0b as a request spacer  
-followredirects Follow 3xx redirects to new location  
-Format Save file (-o) format:  
csv Comma-separated-value  
json JSON Format  
htm HTML Format  
sql Generic SQL (see docs for schema)  
txt Plain text  
xml XML Format  
(if not specified the format will be taken from the file extension passed to -output)  
-Help This help information  
-host Target host/URL  
-id Host authentication to use, format is id:pass or id:pass:realm  
-ipv4 IPv4 Only  
-ipv6 IPv6 Only  
-key Client certificate key file
```



```
kali@kali -
Session Actions Edit View Help

4 Enumerate user names via cgiwrap (/cgi-bin/cgiwrap/-user type requests)
6 Attempt to guess directory names from the supplied dictionary file

-mutate-options Provide information for mutates
-nocheck Don't check for updates on startup
-nocookies Do not use cookies from responses in requests
-nointeractive Disables interactive features
-nolookup Disables DNS lookups
-nossl Disables the use of SSL
-noslash Strip trailing slash from URL (e.g., '/admin/' to '/admin')
-no404 Disables nikto attempting to guess a 404 page
-Option Over-ride an option in nikto.conf, can be issued multiple times
-output+ Write output to this file ('.' for auto-name)
-Pause+ Pause between tests (seconds)
-Platform+ Platform of target (nix, win, all)
-Plugins+ List of plugins to run (default: ALL)
-port+ Port to use (default 80)
-RSAcert+ Client certificate file
-root+ Prepend root value to all requests, format is /directory
-Save Save positive responses to this directory ('.' for auto-name)
-ssl Force ssl mode on port
-Tuning+ Scan tuning:
1 Interesting File / Seen in logs
2 Misconfiguration / Default File
3 Information Disclosure
4 Injection (XSS/Script/HTML)
5 Remote File Retrieval - Inside Web Root
6 Denial of Service
7 Remote File Retrieval - Server Wide
8 Command Execution / Remote Shell
9 SQL Injection
0 File Upload
a Authentication Bypass
b Software Identification
c Remote Source Inclusion
d Webservice
e Administrative Console
x Reverse Tuning Options (i.e., include all except specified)
-timeout+ Timeout for requests (default 10 seconds)
-Userdbs Load only user databases, not the standard databases
all Disable standard dbs and load only user dbs
tests Disable only db_tests and load udb_tests
-useragent Force User-Agent instead of pulling from database
-url+ Target host/URL (alias of -host)
-useproxy Use the proxy defined in nikto.conf, or argument http://server:port
-Version Print plugin and database versions
-vhost+ Virtual host (for Host header)
-404code Ignore these HTTP codes as negative responses (always). Format is "302,301".
-404string Ignore this string in response body content as negative response (always). Can be a regular express
ion.

+ requires a value
```